SIGAP

Sistem Integritas Gerak-cepat untuk Akuisisi Pembuktian

Purwarupa forensik IoMT (*Internet of Military Things*) yang offline-first. Node mendeteksi anomali, mengumpulkan artefak, lalu menandatangani bundle bukti. Keaslian bundle itu bisa diperiksa tanpa server pusat.

DUKUNGAN TEKNOLOGI | DIGITAL FORENSIC TOOLKIT | GO + PYTHON | ED25519 | OFFLINE-FIRST

KATEGORI	Dukungan Teknologi. Situs resmi menyebut *Digital Forensic Toolkit* sebagai contoh kategori ini.
TIM	Pokoknya Ikut Aja Kata Dosen
COBA ONLINE	https://daxxiee0x1.github.io/SIGAP/
KODE SUMBER	https://github.com/Daxxiee0x1/SIGAP
KIT JURI OFFLINE	https://github.com/Daxxiee0x1/SIGAP/releases/latest
DOKUMEN TERKAIT	Slide penjelasan, docs/cara_mencoba.md, docs/bukti_demo.md, docs/threat_model.md, docs/HKI_DAN_ATRIBUSI.md

DAFTAR ISI

01 Ringkasan eksekutif
02 Latar belakang dan masalah
03 Pengguna dan kebutuhan
04 Solusi dan fitur
05 Arsitektur dan teknologi
06 Inovasi teknis
07 Model ancaman
08 Hasil purwarupa dan pengujian
09 Relevansi untuk TNI AD
10 Kelayakan implementasi dan roadmap
11 Batas klaim
12 Cara mencoba
13 Tim, HKI, dan atribusi
A Pemetaan ke kriteria penilaian

01 Ringkasan eksekutif

Saat insiden terjadi di node lapangan, bukti volatil seperti proses dan koneksi jaringan harus diamankan dalam hitungan detik. Pada saat itu link ke pusat sering terputus dan belum ada analis forensik di lokasi.

SIGAP memindahkan langkah pertama forensik ke node. Agen Go yang ringan menjalankan enam aturan deteksi. Saat ada aturan yang terpicu, agen membaca `/proc` secara langsung, menyamarkan kredensial, lalu menghitung SHA-256 setiap artefak. Hasilnya dikemas dalam bundle zip dengan manifest yang ditandatangani Ed25519. Bundle disimpan di outbox dan dikirim ke vault ketika link pulih. Bundle juga bisa dibawa lewat flashdisk dan diperiksa di laptop analis tanpa jaringan.

DIJAMIN
Perubahan, penambahan, atau penghapusan berkas setelah bundle ditandatangani terdeteksi oleh pemegang kunci publik tepercaya.

SATU VERIFIER
Node, laptop analis, vault, dan situs coba online memakai implementasi verifikasi yang sama (`internal/verify`).

HASIL UJI
10 dari 10 skenario manipulasi menghasilkan status yang diharapkan. Penulisan ulang log kustodi oleh admin juga terdeteksi.

SIGAP adalah purwarupa dan bukan sistem produksi. SIGAP tidak menjamin kebenaran isi artefak dari node yang sudah dikuasai penyerang (lihat bagian 11).

02 Latar belakang dan masalah

Sensor, gateway, dan perangkat komputasi di pos terdepan atau kendaraan beroperasi dalam kondisi DDIL (*disconnected, intermittent, limited*). Ketika ada indikasi serangan, misalnya reverse shell atau koneksi keluar yang tidak semestinya, jejaknya cepat hilang. Proses berhenti, koneksi ditutup, dan log tertimpa.

ASPEK	KONDISI SAAT INI (HASIL RISET MEJA TIM)
Pengumpulan bukti	Salinan manual oleh operator yang bukan ahli forensik, atau menunggu analis datang ke lokasi.
Keaslian bukti	Hash sering dihitung belakangan dan secara manual. Perubahan di antara pengumpulan dan analisis tidak bisa dibuktikan.
Rantai kustodi	Formulir kertas atau tabel database yang bisa ditulis ulang tanpa jejak.
Verifikasi	Bergantung pada koneksi ke server pusat, padahal koneksi itulah yang sering tidak tersedia.

RUMUSAN MASALAH

- Bagaimana mengamankan bukti volatil secara otomatis pada detik pertama, tanpa menunggu analis atau koneksi?
- Bagaimana membuktikan bahwa bukti yang tiba di analis sama persis dengan yang dikumpulkan node, walaupun bukti itu berpindah lewat flashdisk?
- Bagaimana membuat catatan kustodi di pusat yang tidak bisa diubah diam-diam, bahkan oleh admin database?

Catatan metode: konteks dan kebutuhan disusun dari riset meja tim dan belum divalidasi lewat wawancara pengguna. Validasi direncanakan pada tahap pilot (bagian 10).

03 Pengguna dan kebutuhan

PERAN	TUJUAN	HAMBATAN	DIJAWAB SIGAP
Operator satuan mengelola sensor di lapangan	Mengamankan bukti dengan cepat walaupun tidak punya keahlian forensik.	Link sering putus dan tidak ada analis di lokasi.	Koleksi berjalan otomatis saat aturan terpicu. Bundle menunggu di outbox sampai link pulih.
Analis forensik memeriksa bukti di laptop	Memastikan bukti asli sebelum menghabiskan waktu untuk menganalisisnya.	Bukti datang lewat flashdisk tanpa jaminan keaslian.	Satu perintah `sigap verify` secara offline, lengkap dengan status dan alasan yang jelas.
Auditor menilai rantai kustodi	Menelusuri siapa menyentuh bukti dan apa hasilnya.	Catatan kertas dan database yang bisa ditulis ulang tanpa jejak.	Log kustodi berantai hash. Tombol "Periksa rantai" menunjukkan entri mana yang diubah.

Proto-persona disusun dari asumsi tim. Ini bukan data wawancara dan tidak mewakili personel tertentu.

KEBUTUHAN YANG BELUM DILAYANI ALAT YANG ADA

Alat live response yang sudah dikenal (misalnya UAC dan Velociraptor) baik untuk host yang terhubung dan dioperasikan analis. SIGAP tidak menggantikannya. SIGAP mengisi celah berikut: koleksi otomatis saat link ke pusat terputus, verifikasi keaslian tanpa server pusat, penolakan bundle yang ditandatangani kunci sah milik penyerang, deteksi admin yang menulis ulang log kustodi, dan agen ringan untuk ARM tanpa runtime tambahan.

04 Solusi dan fitur

Empat langkah pertama berjalan otomatis di node. Hanya langkah verifikasi yang membutuhkan manusia.

1
DETEKSI
Enam aturan yang dievaluasi setiap 2 detik. Alert yang sama dibatasi cooldown.

2
KOLEKSI
Membaca `/proc` langsung, tanpa `ps` atau `ss` yang mungkin sudah dimodifikasi. Kredensial disamarkan.

3
TANDA TANGAN
SHA-256 setiap artefak masuk ke manifest. Manifest ditandatangani Ed25519 dalam berkas terpisah.

4
SIMPAN DAN TERUSKAN
Bundle menunggu di outbox. Uplink dicoba ulang dan tidak pernah menunda deteksi.

5
VERIFIKASI
Analis atau vault menjalankan verifier yang sama. Kunci publik diambil dari trust store lokal.

ATURAN DETEKSI

- Pola reverse shell di baris perintah (`/dev/tcp/`, `nc -e`, `bash -i`, dan lainnya)
- Koneksi keluar di luar allowlist CIDR
- Port listen baru dibanding baseline
- Perubahan hash berkas konfigurasi yang dipantau
- Lonjakan CPU atau memori selama beberapa sampel
- Eksekusi dari `/tmp`, `/var/tmp`, atau `/dev/shm`

ISI SETIAP BUNDLE

- `manifest.json` dan `manifest.sig` (Ed25519)
- Enam artefak: daftar proses, koneksi jaringan, potongan log, konfigurasi yang sudah diredaksi, metadata node, dan alert pemicu
- Nomor urut dan hash bundle sebelumnya, sehingga celah atau urutan yang diacak terlihat saat bundle diperiksa

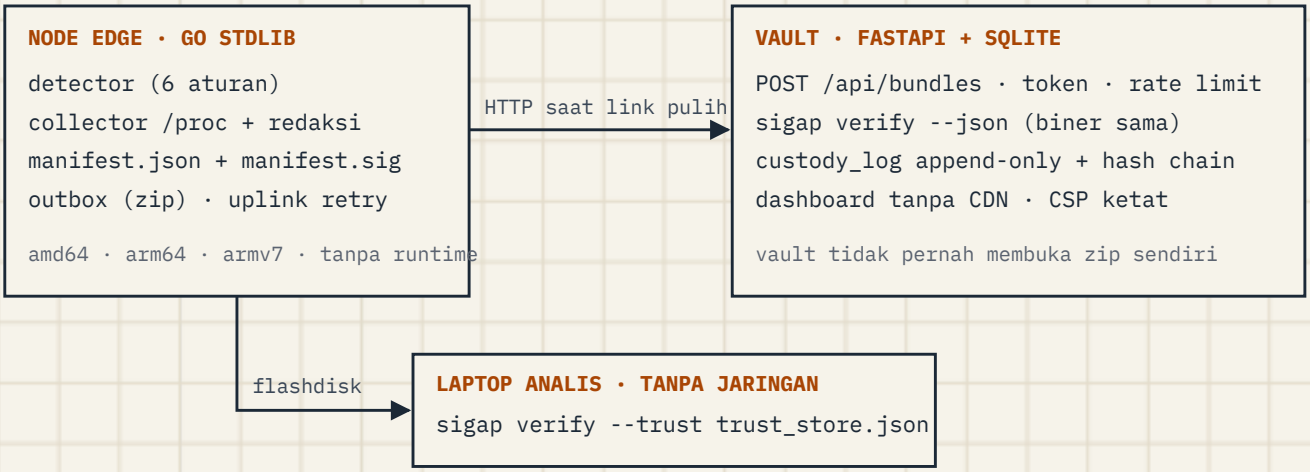
Aturan berbasis kaidah yang bisa dijelaskan. Tidak ada klaim deteksi berbasis ML.

LIMA STATUS VERIFIKASI

Status yang sama dipakai di CLI, kode keluar, API vault, dashboard, dan situs coba online. Setiap status punya tindakan yang tetap bagi analis.

STATUS	EXIT	ARTI	TINDAKAN ANALIS
VALID	0	Tanda tangan sah dari kunci di trust store, dan semua hash cocok.	Lanjutkan analisis.
TAMPERED	2	Byte artefak, manifest, atau tanda tangan berubah, atau ada berkas tak terdaftar.	Karantina, laporkan, dan minta salinan baru.
INCOMPLETE	3	Berkas yang tercantum di manifest hilang dari zip.	Minta bundle utuh dari outbox node.
UNTRUSTED_SIGNER	4	`key_id` tidak ada, dicabut, atau kedaluwarsa di trust store.	Periksa trust store dan asal bundle.
MALFORMED	5	Bukan zip, nama berbahaya (`../`, absolut, symlink), atau bom dekompresi.	Jangan diekstrak. Simpan sebagai sampel.

05 Arsitektur dan teknologi



URUTAN PEMERIKSAAN VERIFIER

1. Batas struktur: ukuran maksimal 20 MB, 50 berkas, nama sesuai allowlist, tanpa symlink, total terdekompresi maksimal 100 MB.
2. Cari `key_id` di trust store lokal, bukan dari bundle.
3. Verifikasi Ed25519 atas byte `manifest.json` sebelum di-parse.
4. Parse ketat dan cocokkan `signer_key_id`.
5. Cocokkan SHA-256 dan ukuran setiap artefak. Berkas tak terdaftar menghasilkan TAMPERED, berkas hilang menghasilkan INCOMPLETE.

TEKNOLOGI

KOMPONEN	TEKNOLOGI
Agen dan verifier	Go 1.22, hanya pustaka standar, satu biner statis (sekitar 5,6 MB untuk amd64)
Kriptografi	Ed25519 (RFC 8032), SHA-256
Vault	Python 3.11+, FastAPI, SQLite
Situs coba online	Verifier Go dikompilasi ke WebAssembly
Demo dan uji	Docker Compose, pytest, GitHub Actions

06 Inovasi teknis

SATU IMPLEMENTASI VERIFIKASI

Node, laptop analis, vault, dan browser menjalankan kode `internal/verify` yang sama. Hasil VALID atau TAMPERED tidak mungkin berbeda antara lapangan dan pusat.

KUNCI HANYA DARI TRUST STORE

Kunci publik tidak pernah diambil dari bundle. Bundle yang ditandatangani kunci Ed25519 sah milik penyerang tetap ditolak sebagai UNTRUSTED_SIGNER.

TANDA TANGAN SEBELUM PARSE

Ed25519 diverifikasi atas byte mentah manifest sebelum JSON dibaca. Isi manifest yang belum terautentikasi tidak pernah ditampilkan di dashboard.

REDAKSI SEBELUM HASH

Nilai seperti `api_key` disamarkan sebelum SHA-256 dihitung, dan jumlah redaksinya dicatat di manifest. Bukti tetap bisa dibagikan tanpa membocorkan kredensial.

LOG KUSTODI BERANTAI HASH

Setiap peristiwa di vault dirantai dengan hash entri sebelumnya. Head hash diekspor, sehingga admin yang menulis ulang SQLite akan ketahuan.

DIBUAT UNTUK NODE LAPANGAN

Satu biner statis tanpa dependensi pihak ketiga untuk amd64, arm64, dan armv7. Koleksi dari `/proc` tidak bergantung pada utilitas sistem yang mungkin sudah diganti penyerang.

07 Model ancaman

Penyerang yang ditangani dapat membaca dan mengubah bundle setelah bundle dibuat, baik saat transit, di penyimpanan, maupun di tangan pihak lain. Penyerang ini **tidak** memegang kunci penandatanganan node.

ANCAMAN	PENANGANAN	UJI
Ubah byte artefak	SHA-256 di manifest bertanda tangan	`01_flip_byte`
Tambah atau hapus berkas	Isi zip harus sama dengan daftar di manifest	`02_add_unlisted` `03_remove_listed`
Ubah manifest	Ed25519 atas byte manifest	`04_edit_manifest`
Tukar tanda tangan	Verifikasi gagal	`05_swap_signature`
Tanda tangan kunci penyerang	Kunci hanya dari trust store	`06_kunci_asing`
Zip slip, symlink, bom dekompresi	Validasi struktur sebelum entri dibaca	`07a, 07b, 08`
Replay atau duplikat	Hash bundle unik, dicatat `duplicate_ignored`	API vault
XSS lewat `node_id` atau catatan	`textContent` dan CSP ketat	Dashboard
Kebocoran kredensial	Redaksi sebelum hashing, jumlahnya dicatat	pytest
Admin menulis ulang log	Hash chain dan head hash yang diekspor	pytest

Di luar model: node yang sudah dikompromi (artefak bisa dipalsukan sebelum ditandatangani, rootkit kernel tidak ditahan), pencurian kunci dari node, kebenaran waktu node, dan distribusi kunci otomatis.

08 Hasil purwarupa dan pengujian

Purwarupa sudah berjalan dari ujung ke ujung: deteksi, koleksi, tanda tangan, store-and-forward, verifikasi di vault, verifikasi offline, dan audit rantai kustodi. Angka di bawah berasal dari satu run lengkap pada 5 November 2026. Keluaran aslinya dicatat di `docs/bukti_demo.md`.

SKENARIO	HASIL	WAKTU
Bundle asli dari node	VALID	935 µs
Ubah 1 byte artefak	TAMPERED	968 µs
Tambah berkas tak terdaftar	TAMPERED	810 µs
Hapus berkas terdaftar	INCOMPLETE	821 µs
Ubah manifest	TAMPERED	624 µs
Ganti tanda tangan	TAMPERED	681 µs
Zip slip `../../etc/cron.d`	MALFORMED	127 µs
Entri symlink	MALFORMED	79 µs
Bom dekompresi 110 MB	MALFORMED	606 µs
Kunci Ed25519 sah milik penyerang	UNTRUSTED_SIGNER	177 µs

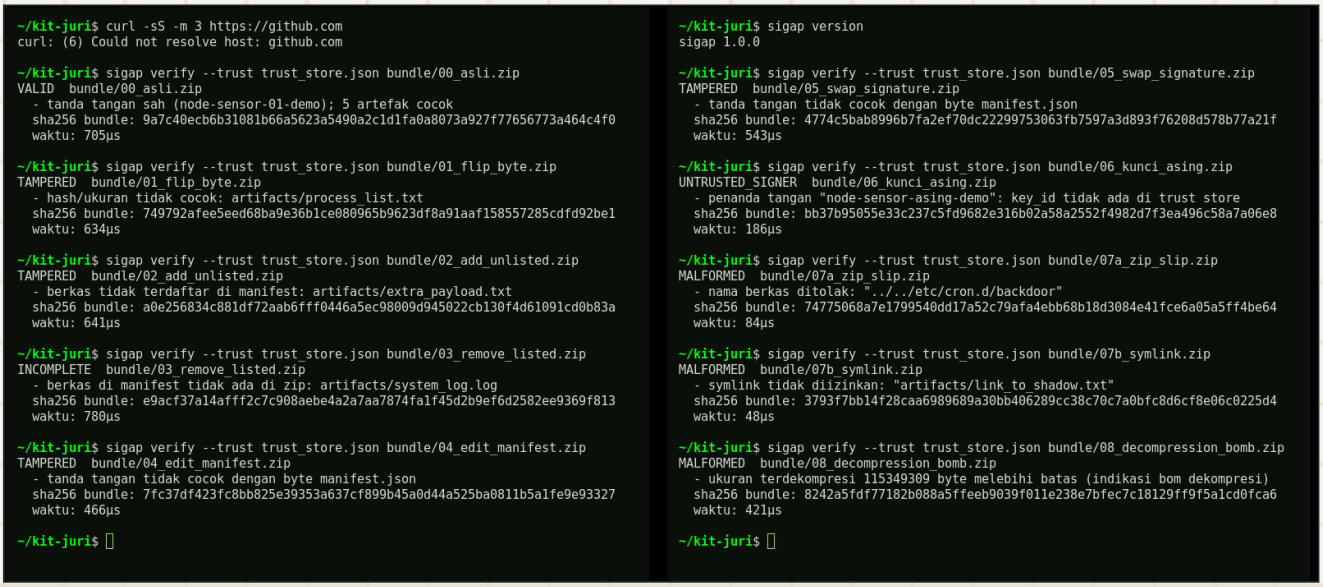
DI VAULT (API)

- Hasil verifikasi sama persis dengan verifikasi offline.
- Replay bundle asli dicatat `duplicate_ignored`.
- Unggahan tanpa token ditolak dengan HTTP 401.
- Rantai 9 entri utuh. Setelah satu entri ditulis ulang langsung di SQLite, pemeriksaan rantai menunjukkan **PUTUS di entri #4**.

UJI OTOMATIS

`go vet`, `go test`, `pytest`, dan `docker compose build` dijalankan GitHub Actions pada setiap push.

Waktu verifikasi diukur pada satu mesin dan hanya menunjukkan orde besaran, bukan benchmark.



Tangkapan layar asli: dua jendela xterm menjalankan `sigap verify` atas 10 contoh bundle dari kit juri, di dalam namespace tanpa jaringan (`curl` ke github.com gagal). Waktu verifikasi berbeda tiap run.

09 Relevansi untuk TNI AD

Satuan yang mengoperasikan sensor, gateway, dan perangkat IT/OT di lapangan membutuhkan bukti insiden yang bisa dipertanggungjawabkan, walaupun tidak ada koneksi dan tidak ada analis di lokasi. SIGAP dirancang untuk kondisi tersebut.

SKENARIO PENGGUNAAN	PERAN SIGAP
Node sensor di pos terdepan atau kendaraan dengan link DDIL	Agen mengamankan bukti saat insiden, lalu bundle menunggu di outbox sampai link pulih.
Bukti dibawa lewat media fisik	Analis memverifikasi keaslian di laptop tanpa jaringan sebelum bukti dianalisis lebih lanjut.
Pusat siber yang menerima bukti dari banyak node	Vault memverifikasi ulang setiap bundle dan mencatat kustodi yang perubahannya bisa dideteksi.
Audit pasca-insiden	Auditor membandingkan head hash yang diekspor dengan isi log kustodi.

Skenario di atas adalah rancangan tim berdasarkan riset meja, bukan deskripsi infrastruktur TNI AD yang sebenarnya.

10 Kelayakan implementasi dan roadmap

KEMUDAHAN PENERAPAN

- Satu biner statis untuk amd64, arm64, dan armv7. Tidak perlu runtime di node.
- Kit instalasi offline yang memeriksa SHA256SUMS, berisi biner, image Docker, dan wheelhouse Python untuk vault.
- Demo Docker Compose di jaringan internal tanpa akses internet setelah build.
- Konfigurasi satu berkas JSON: aturan, allowlist, berkas yang dipantau, dan alamat vault.

RENCANA TAHAP PENGEMBANGAN

TAHAP	KEGIATAN
1 · Lab	Uji di perangkat ARM nyata, tambah uji beban, dan perbaiki temuan UX.
2 · Pilot	Pasang di beberapa node satuan bersama analis, lalu ukur keberhasilan tugas dan skor SUS.
3 · Perluasan	Distribusi kunci terkelola, integrasi dengan SIEM, dan prosedur operasi standar.

Rencana, belum dilaksanakan.

ROADMAP TEKNIS

R1
Kunci node di TPM atau secure element, agar pencurian kunci jauh lebih sulit.

R2
Cap waktu tepercaya RFC 3161, agar waktu tidak hanya dilaporkan sendiri oleh node.

R3
Tanda tangan pasca-kuantum ML-DSA berdampingan dengan Ed25519.

R4
Perbaikan UX dari evaluasi heuristik dan uji SUS dengan pengguna nyata.

11 Batas klaim

- SIGAP bukan sistem produksi dan bukan pengganti Velociraptor, UAC, atau Autopsy.
- Timestamp di manifest dilaporkan sendiri oleh node. Waktu tepercaya hanya `received_at` di vault.
- Distribusi dan pencabutan kunci offline masih manual, yaitu dengan menyalin `trust_store.json`.
- Hasil deteksi diukur pada skenario simulasi buatan tim, bukan klaim kemampuan deteksi secara umum.
- SIGAP tidak mengklaim bahwa bukti yang dihasilkannya pasti diterima dalam proses hukum.

12 Cara mencoba

JALUR	LANGKAH	WAKTU
Coba online	Buka `daxxiee0x1.github.io/SIGAP`. Verifier berjalan di browser lewat WebAssembly. Juri bisa memverifikasi 10 contoh bundle, mengubah atau menghapus berkas lalu melihat bundle ditolak, dan mengunggah bundle sendiri. Bundle tidak dikirim ke server mana pun.	±1 menit
Kit juri offline	Unduh `sigap-kit-juri-*.zip` dari Releases, ekstrak, lalu jalankan `coba.cmd` (Windows) atau `./coba.sh` (macOS dan Linux). Hasil yang diharapkan: *10 cocok, 0 beda*.	±1 menit
Demo lengkap Docker	`make up`, buka `http://127.0.0.1:8000`, lalu `make inject-reverse_shell` dan `make tamper-demo`. Demo penuh sesuai video: `AUTO=1 make demo`.	±3 menit setelah build

Skenario serangan hanya simulasi: reverse shell berupa proses tidur dengan pola di baris perintah, dan lalu lintas jaringan hanya menuju rentang dokumentasi 203.0.113.0/24 di jaringan Docker internal.

13 Tim, HKI, dan atribusi

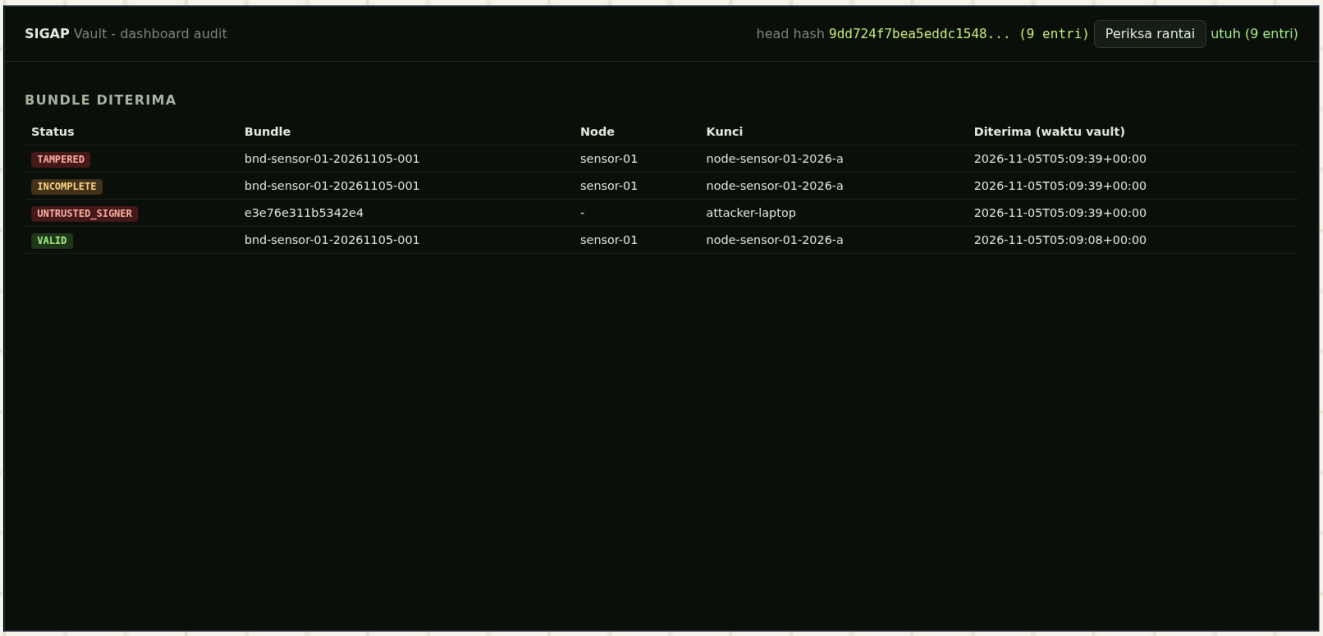
TIM	Pokoknya Ikut Aja Kata Dosen
HAK CIPTA	© 2026 Tim Pokoknya Ikut Aja Kata Dosen. Hak kekayaan intelektual tetap milik tim. Penyelenggara memperoleh lisensi non-eksklusif sesuai Rulebook bagian N.
PIHAK KETIGA	Agen Go hanya memakai pustaka standar. Vault memakai FastAPI, Uvicorn, dan python-multipart (MIT, BSD, Apache). Huruf IBM Plex memakai SIL OFL 1.1. Atribusi lengkap ada di `docs/HKI_DAN_ATRIBUSI.md`.
KARYA PRE-EXISTING	Tidak ada kode program yang sudah ada sebelum periode program.
ALAT BANTU AI	Claude (Anthropic), termasuk lewat Figma Make, dipakai sebagai asisten untuk kode, dokumentasi, slide, dan proposal. Seluruh hasil ditinjau dan diuji oleh tim.
KONTEN	Tidak ada malware aktif dan tidak ada data pribadi pihak ketiga. Kredensial di repositori hanyalah nilai demo.

A Pemetaan ke kriteria penilaian

Rulebook Kartika Cyber Hackathon 2026 bagian H, beserta letak buktinya di proposal dan repositori.

KRITERIA	BOBOT	BUKTI
Relevansi dan manfaat	25%	Konteks DDIL, kebutuhan tiga peran, dan skenario penggunaan (bagian 02, 03, 09).
Inovasi teknis	25%	Satu verifier di semua tempat, kunci hanya dari trust store, redaksi sebelum hash, dan log kustodi berantai (bagian 05 sampai 07).
Fungsionalitas purwarupa	25%	10 dari 10 skenario sesuai harapan, verifikasi di vault, deteksi penulisan ulang log, situs coba online, kit juri, dan demo Docker (bagian 08 dan 12).
Kelayakan implementasi	15%	Biner statis multi-arsitektur, kit offline, tahap pilot, roadmap, dan batas klaim yang jujur (bagian 10 dan 11).
Kualitas dokumentasi	10%	Proposal ini, slide penjelasan, README, `docs/` (arsitektur, model ancaman, bukti demo, cara mencoba, HKI), dan video demo.

TAMPILAN PURWARUPA



Tangkapan layar asli dashboard audit vault: empat status verifikasi, head hash, dan rantai kustodi *utuh (9 entri)*. Tangkapan layar lain ada di folder `screenshot/`.

Bukti yang tidak bisa diuji tidak bisa dipercaya.

SIGAP membuat setiap bukti bisa diuji, bahkan tanpa koneksi.